MFA and Sign-in Policies

Project: *Okta Identity Lab |* ***Author:*** *Ismayeel Khan |* ***Date:*** *October 26, 2026 |* ***Environment:*** *Okta Integrator Free Plan*

---

1. Goal

The goal of this checkpoint was to make signing in safer: turn on security alerts, require users to set up a second factor, and write a rule that asks for extra verification when someone signs in to an app.

2. Concepts: MFA and Policies

Multi-factor authentication (MFA) means a user proves who they are with more than a password. A password is something you *know*. The second factor is usually something you *have*, such as a phone, a passkey, or an email inbox.

Okta uses two different kinds of policy for this, and I had to learn the difference:

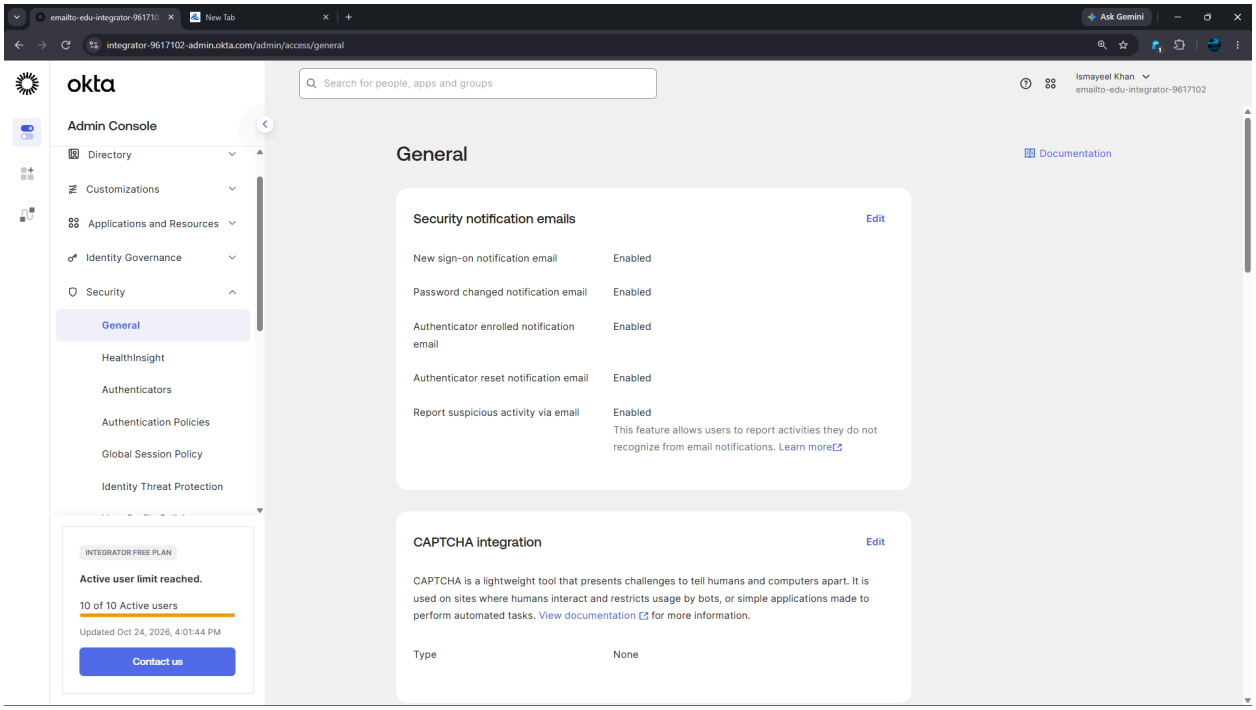
- **Authenticator enrollment policy:** decides *which* factors users must or may set up (for example, "Email is required, Okta Verify is optional").
- **Authentication (sign-in) policy:** decides *when* Okta asks for an extra check while someone signs in to an app.

3. Step 1: Turn On Security Notification Emails

In Checkpoint 1, all security notification emails were disabled by default. I turned on:

- New sign-on notification
- Password changed notification
- Authenticator enrolled notification
- Authenticator reset notification

In a real company, these emails warn users when something changes on their account, so they can report anything they do not recognize.

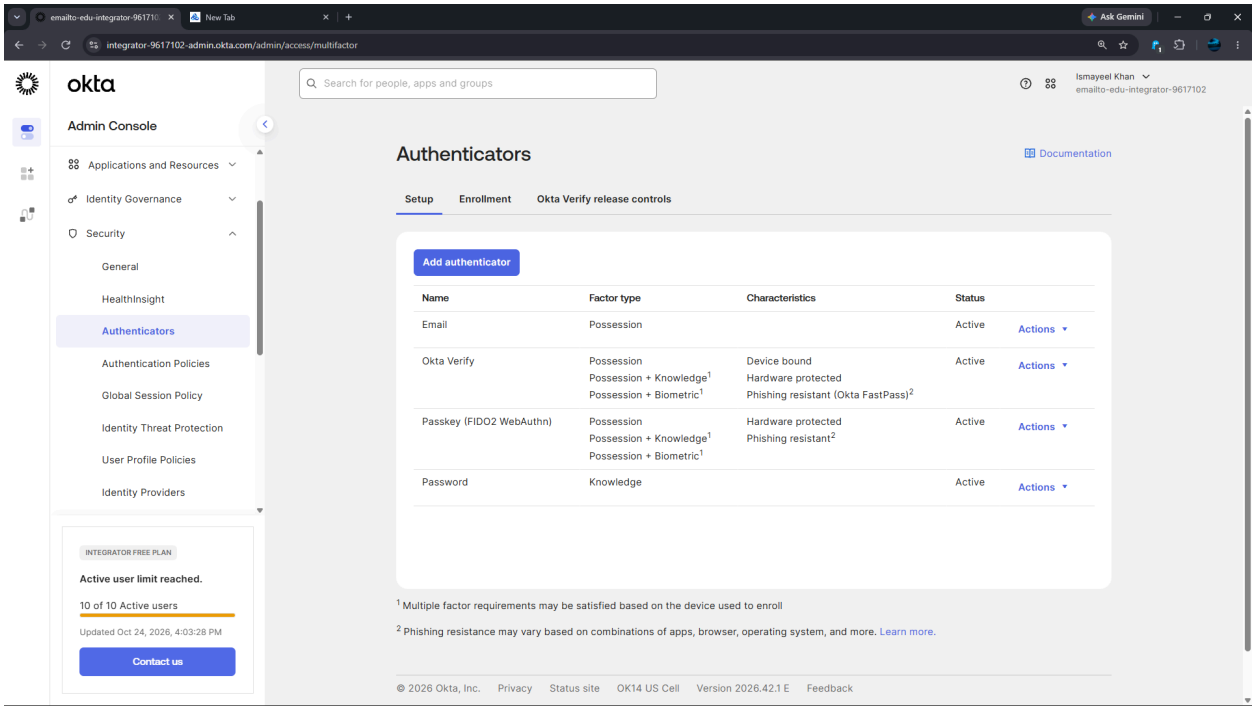


Security notification emails now enabled. (Compare with the "disabled" screenshot in Document 1.)

4. Step 2: Review the Available Authenticators

Next I checked which authenticators the org supports. Four are active: Email, Okta Verify, Passkey (FIDO2 WebAuthn), and Password.

Okta Verify and Passkey are marked **phishing resistant**, which means an attacker cannot easily trick a user into handing them over. Email codes are not phishing resistant. This detail matters later in the troubleshooting section.



Authenticators available in the org and their characteristics.

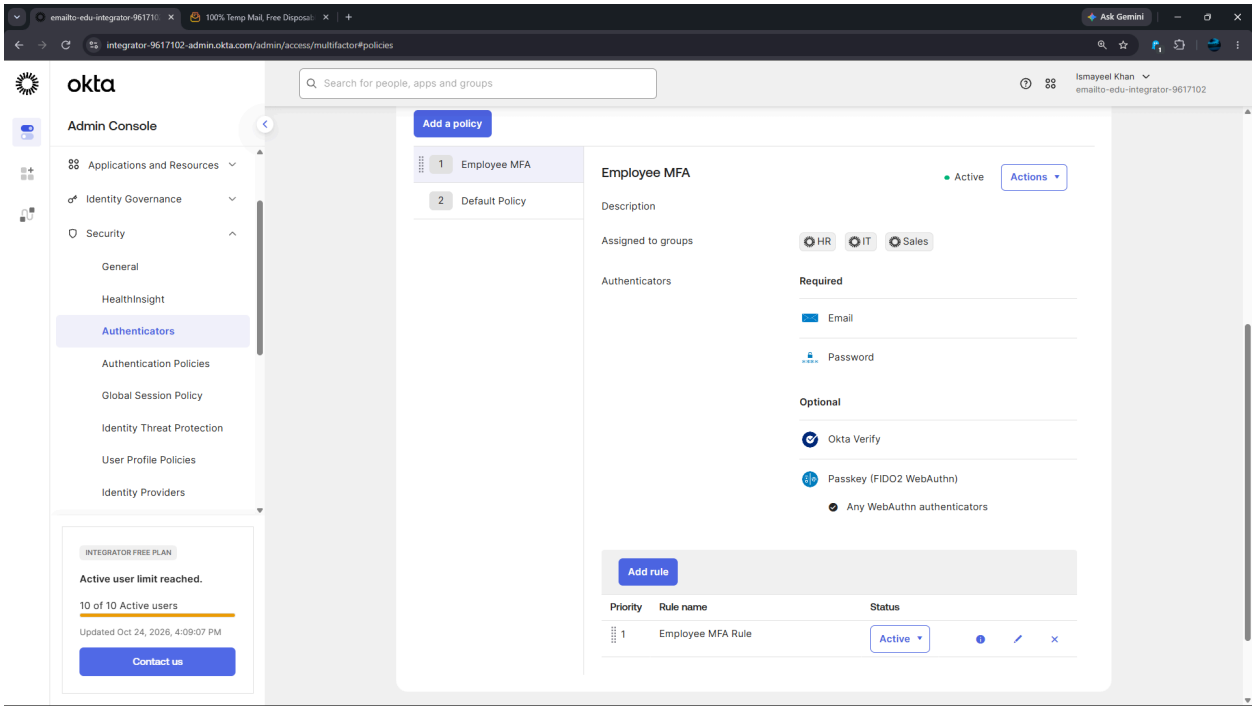
5. Step 3: Create an Enrollment Policy

I created an enrollment policy called **Employee MFA**, assigned to the **IT, HR, and Sales** groups. I did not include my own admin account, which has separate protection.

- **Required:** Email and Password
- **Optional:** Okta Verify and Passkey

I made Email the required factor because I have eight fake users and no phones to enroll them with. Email codes are easy to test in a lab. In a real company, I would require something stronger.

I also added a rule named **Employee MFA Rule** that allows enrollment from any location, for all authenticators.



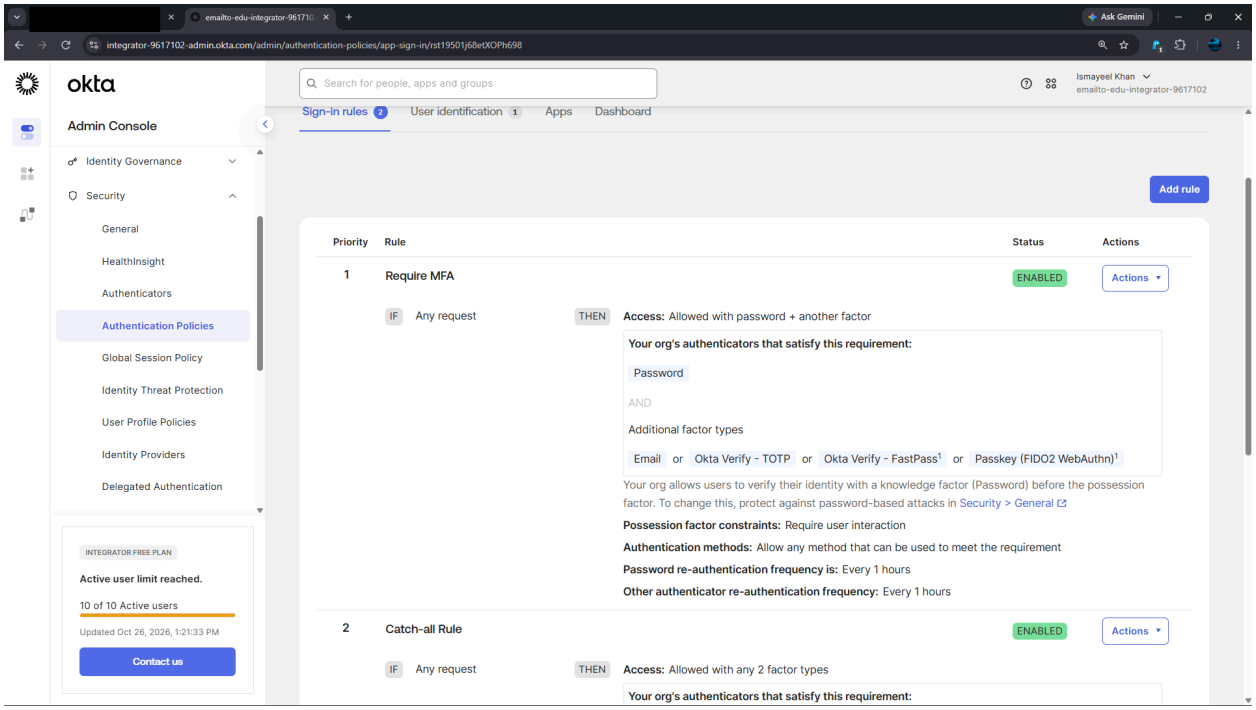
Employee MFA enrollment policy, assigned to HR, IT, and Sales.

6. Step 4: Create a Sign-in Policy and Rule

Next I created an authentication policy called **Sales Wiki - Extra Verification**, with one rule named **Require MFA**:

- **Access:** allowed with password plus another factor
- **Re-authentication:** every 1 hour
- **Position:** above the built-in Catch-all Rule, because Okta reads rules from top to bottom

I left the Catch-all Rule alone, since it is the safety net at the bottom.

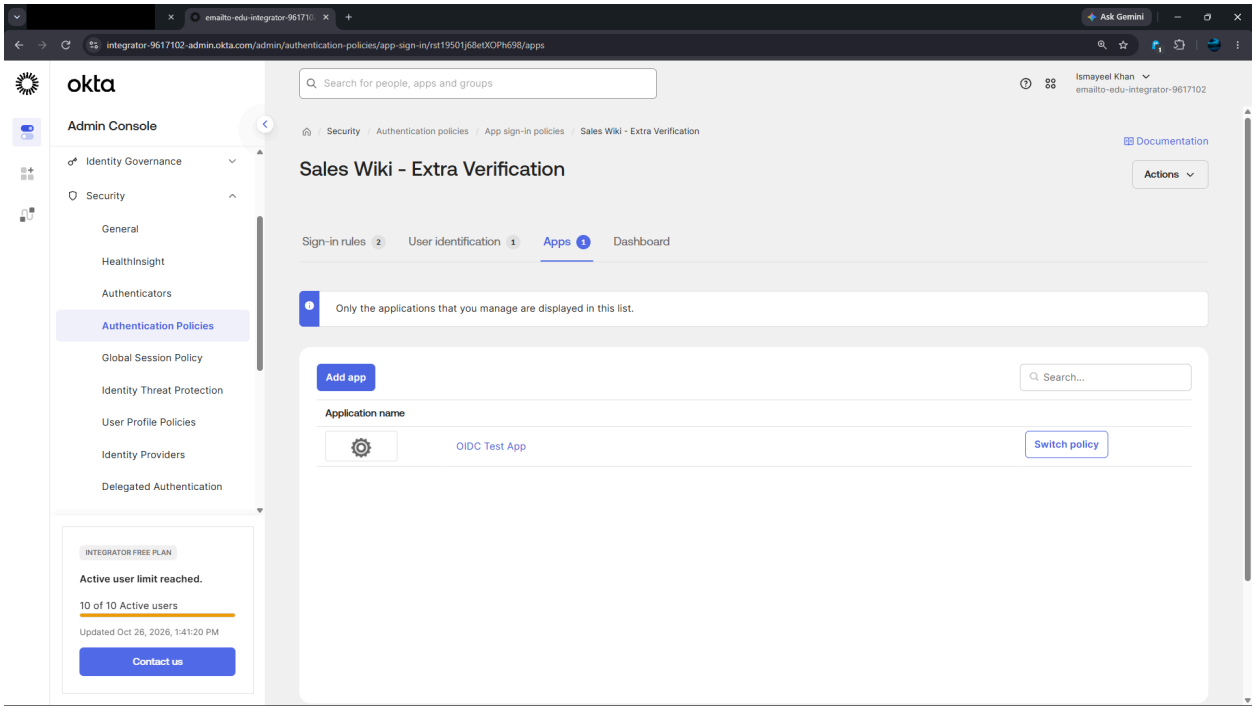


Require MFA rule after the fix. Email is now an accepted second factor.

Which app does the policy protect?

My plan was to attach this policy to the Company Wiki bookmark app. That did not work: a bookmark app's Sign On page says it "does not perform sign-on to an app," so there is no sign-in step for a policy to control. Policies only apply to apps where Okta handles the login.

I attached the policy to the **OIDC Test App** instead. The policy keeps its original name, but it now protects the OIDC app.

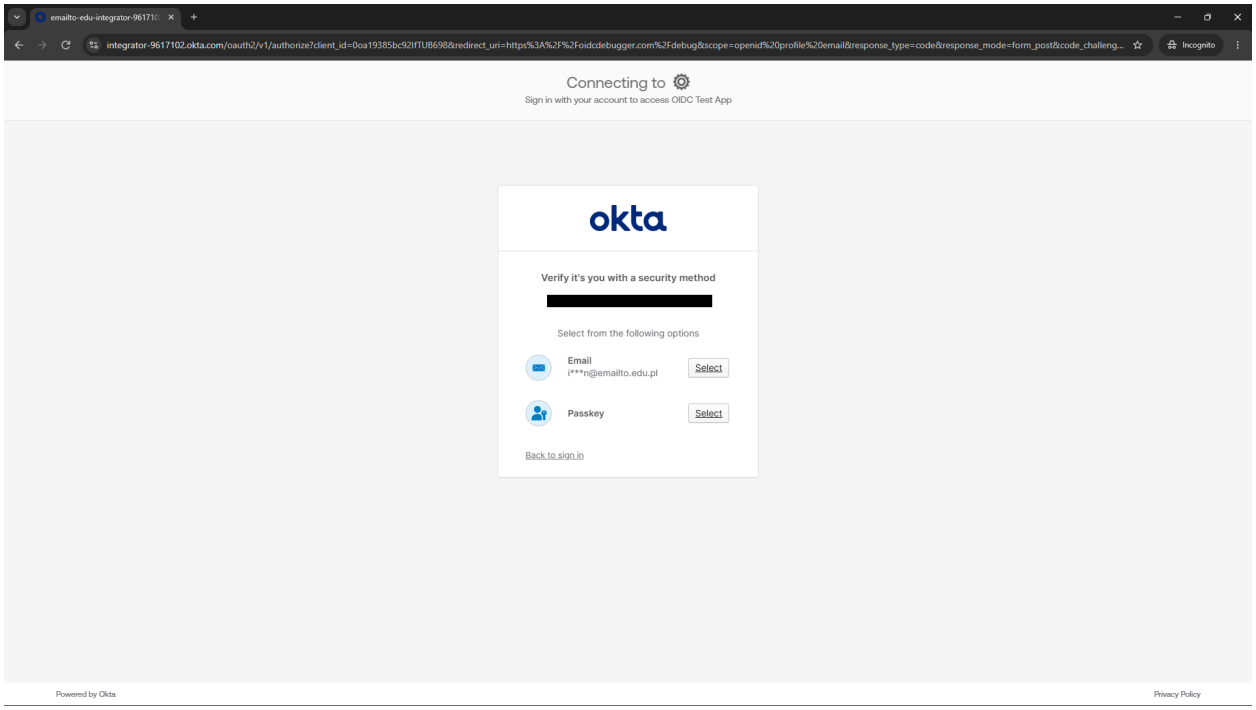


Policy attached to the OIDC Test App.

7. Step 5: Test It as a User

I tested with an IT user (Rohan Mehta) in a private window. I signed in through the OIDC debugger from Checkpoint 3. After the password, Okta stopped and asked: **"Verify it's you with a security method,"** offering Email or Passkey.

I chose Email, got the code in my inbox, entered it, and the sign-in completed.

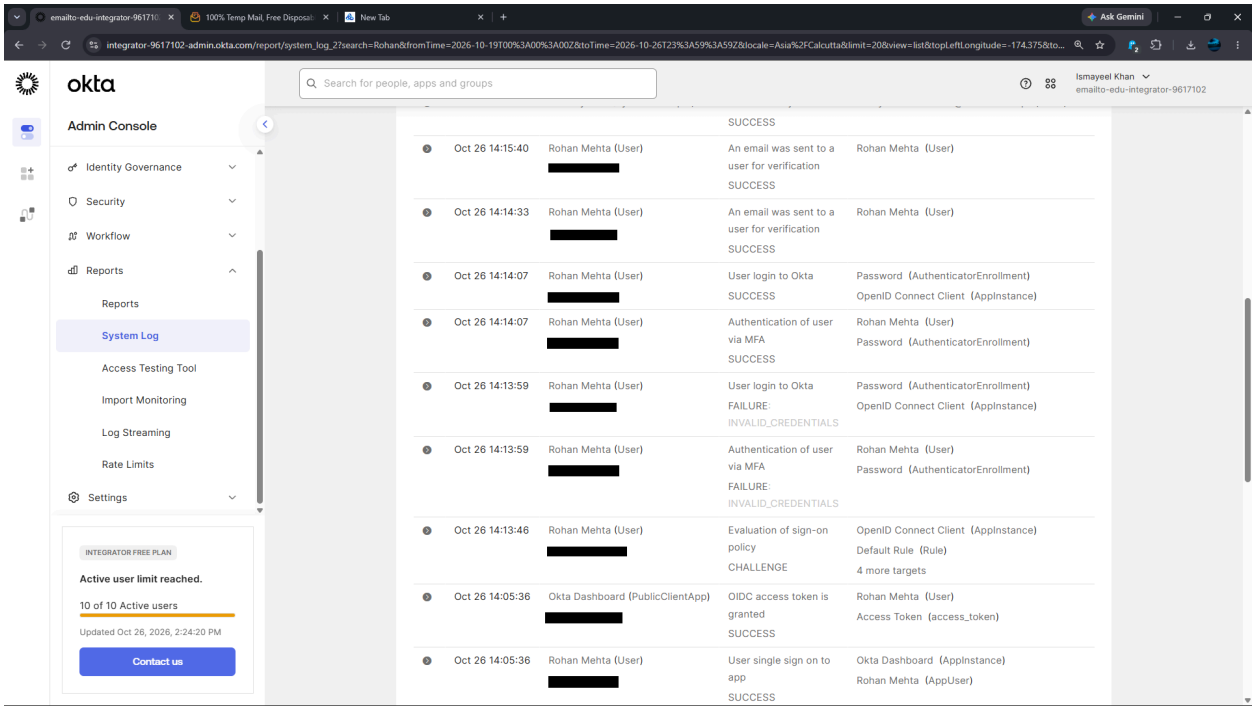


Okta asks for a second factor before letting the user in.

8. Evidence in the System Log

I traced this sign-in in the System Log. The log shows the sequence in order:

1. The sign-on policy evaluated the request and returned **CHALLENGE**, meaning "prove who you are first."
2. A login attempt failed with **INVALID_CREDENTIALS**: I typed the password wrong once.
3. A second attempt a few seconds later succeeded.
4. Okta sent a verification email. It shows two emails because I clicked "Send again."



System Log showing the challenge, a failed password, a successful password, and the verification email. (IP addresses blacked out.)

9. Troubleshooting Story: Email Was Missing

When I first saved the Require MFA rule, the box listing which factors could satisfy the rule showed only **Okta Verify** and **Passkey**. **Email was not listed.** My test users had no phones or passkeys, so none of them could have passed the check and they would have been locked out.

Step	What I did
Identify	The rule's list of accepted factors showed only Okta Verify and Passkey, with no Email.
Find the cause	The rule's possession-factor constraint was set to **Phishing resistant**. Email codes are not phishing resistant, so Okta hid Email from the list.
Fix	I edited the rule and unticked **Phishing resistant**. I kept "Require user interaction."

Step	What I did
Verify	The rule's list then showed Email, Okta Verify (TOTP), Okta Verify (FastPass), and Passkey. The test sign-in then asked for Email.

Trade-off: I relaxed this setting only so I could test with email in a lab. In a real company, I would keep phishing resistance turned on for important apps and use passkeys or Okta Verify.

10. Other Problems I Ran Into

- **A bookmark app cannot take a sign-in policy.** I moved the policy to the OIDC app (see Section 6).
- **Admin session got in the way of tests.** I used private windows so Okta would not reuse my admin session.
- **The temporary inbox is unreliable.** Reloading the temporary mail page lost a message, so I clicked "Send again." This made me realize that email-based MFA is only as safe as the inbox behind it.

11. Key Concepts I Learned

- **Enrollment policy vs. sign-in policy:** one controls which factors exist, the other controls when they are asked for.
- **Rule order matters:** Okta reads rules top to bottom, so the first matching rule wins.
- **Phishing-resistant factors:** stronger, but they can limit which methods users are allowed.
- **Notification emails:** a simple, free control that alerts users to suspicious account changes.
- **Logs show the full story:** challenge, failure, success, and email, in order.

12. Limits and Notes

- I did not capture a screenshot of the verification email in the inbox or of the final success page, so the log and the prompt are my evidence.
- The phishing-resistant requirement was relaxed on one rule for testing.
- The policy is named for the Sales Wiki but protects the OIDC Test App, because bookmark apps cannot use sign-in policies.
- All users and data are fake.

13. What I Learned and What Is Next

The main lesson from this checkpoint: **a second factor only protects you if every user can actually complete it, so test the policy before relying on it.**

Next, in Checkpoint 5, I run the employee life cycle: a new hire joins, one person changes teams, and one person leaves.